

UNIVERSITÉ HASSAN 1^{er}
FACULTÉ DES SCIENCES ET TECHNIQUES

**Rapport d'incident SOC : Détection de
reconnaissance réseau (Nmap) via Suricata
et ELK Stack – Lab du 25 avril 2026**

Réalisé par :

Meryem Jarti

Encadré par :

Pr. Chaimae Azroumahli

Année universitaire : 2025 - 2026

Table des matières

Table des figures :	3
Table des tableaux :	3
1. Résumé exécutif :	4
2. Infrastructure du lab :	4
3. Chronologie de l'incident (Timeline) :	5
3.1 Phase de préparation (avant 15:19) :	5
3.2 Scan 1 -Découverte réseau : 15:19 UTC+1	5
3.3 Scan 2 -Scan SYN furtif (stealth) : 15:20 UTC+1	6
3.4 Scan 3 -Détection de services et versions : 15:26 UTC+1	7
3.5 Scan 4 -Détection OS : 15:27 UTC+1	8
3.6 Scan 5 -Scan agressif complet : 15:28 UTC+1	9
4. Analyse du Dashboard Kibana – Visualisation SOC :	11
4.1 Visualisation 1 : Compteur global d'alertes (KPI)	11
4.2 Visualisation 2 : Évolution temporelle des alertes	12
4.3 Visualisation 3 : Top signatures déclenchées	12
4.4 Visualisation 4 : Top Sources IP (Pie chart)	13
4.5 Visualisation 5 : Types d'attaques (bar chart)	14
4.6 Visualisation 6 — Top ports ciblés	15
5. Analyse des log Suricata - fast.log	16
6. Analyse Kibana Discover - EVE.JSON	18
7. Résumé des indicateurs de compromission (IoC)	19
8. Recommandations de remédiation :	19
Conclusion :	20

Table des figures :

Figure 1 Topologie du laboratoire.....	4
Figure 2 Dashboard Kibana Baseline pré-attaque.....	5
Figure 3 Scan 1 – Commande nmap -sn	6
Figure 4 Scan 2 – Commande nmap -sS.....	7
Figure 5 Scan 3 – Commande nmap -sV	8
Figure 6 Scan 4 – Commande nmap -O.....	9
Figure 7 Scan 5 – Commande nmap -A.....	10
Figure 8 KPI Kibana – Total des alertes (42)	11
Figure 9 KPI Kibana – 18 alertes concentrées sur la journée du 25 avril 2026.	11
Figure 10 Graphique temporel – Pic isolé d’alertes entre 15h00 et 16h00.	12
Figure 11 Top signatures déclenchées	13
Figure 12 Diagramme circulaire – Top sources IP	14
Figure 13 Histogramme – Types d’attaques détectées.....	15
Figure 14 Top ports ciblés	16
Figure 15 Extrait du fichier fast.log de Suricata	17
Figure 16 Interface Kibana Discover	18

Table des tableaux :

Tableau 1 Infrastructure du laboratoire.....	4
Tableau 2 Répartition des alertes par IP source	13
Tableau 3 Top 5 des ports ciblés.....	15
Tableau 4 Indicateurs de compromission (IoC)	19

1. Résumé exécutif :

Dans le cadre d'un exercice de détection en environnement de laboratoire, une activité de reconnaissance réseau a été détectée en temps réel par le système IDS Suricata, corrélé avec la plateforme SIEM ELK Stack.

L'origine de l'activité est la machine Kali Linux 192.168.10.10, qui a effectué une série de scans Nmap successifs contre la cible 192.168.10.20 entre 15h19 et 15h28 UTC+1. Le SIEM Kibana a enregistré un total de 42 alertes sur une période de 30 derniers jours, dont 18 alertes concentrées le 25 avril 2026, journée de l'exercice.

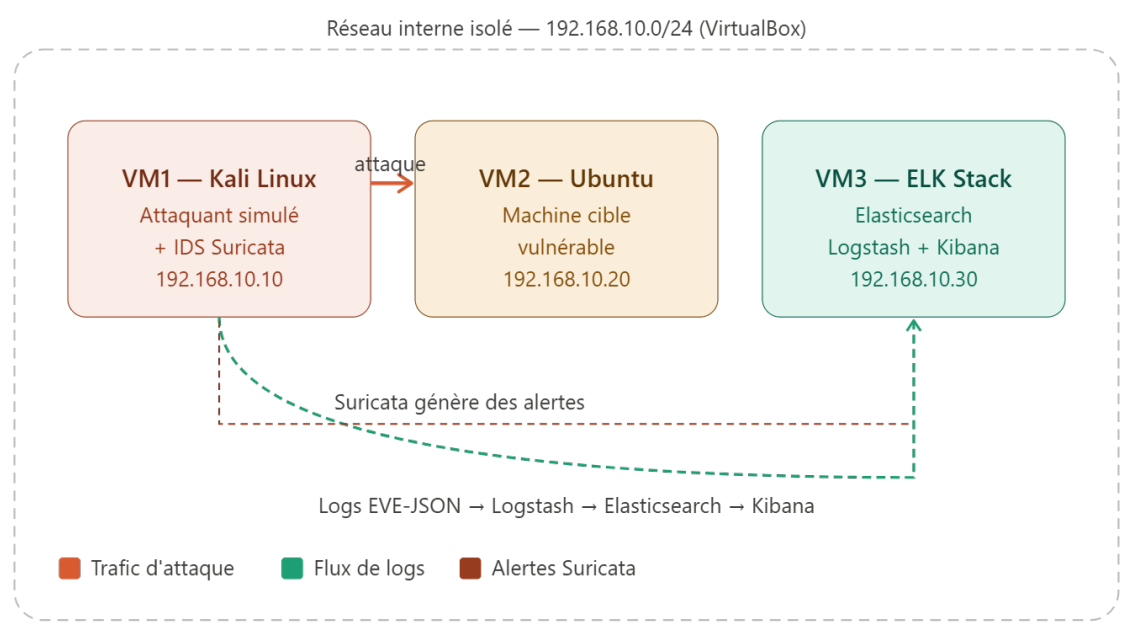


Figure 1 Topologie du laboratoire

L'analyse des signatures déclenchées, des IPs sources et des ports ciblés confirme sans ambiguïté une activité de type reconnaissance réseau automatisée, correspondant à la phase 1 de la Cyber Kill Chain (Lockheed Martin) : Reconnaissance. Aucune tentative d'exploitation n'a été détectée au-delà de cette phase.

2. Infrastructure du lab :

Tableau 1 Infrastructure du laboratoire

Rôle	Hostname	IP
Attaquant	Kali Linux	192.168.10.10
Cible	Target (Ubuntu Server)	192.168.10.20

SIEM / IDS	ELK Stack + Suricata	192.168.10.30
-------------------	----------------------	---------------

Toutes les machines appartiennent au même réseau interne isolé 192.168.10.0/24. La topologie est un réseau plat sans segmentation, ce qui, dans un contexte réel, constituerait une faiblesse architecturale (absence de VLAN, pas de pare-feu inter-zone).

3. Chronologie de l'incident (Timeline) :

3.1 Phase de préparation (avant 15:19) :

Avant le déclenchement de l'attaque, le dashboard Kibana affichait un compteur global de 25 alertes sur les 30 derniers jours, avec une activité résiduelle liée à des scans antérieurs de test. Le graphique temporel montrait une ligne quasi plate, sans pic notable confirmant l'état de repos du réseau.

Lecture analyste : Ce baseline pré-attaque est essentiel. Il établit la normal du système et aide à identifier plus facilement le pic d'activité lié à l'exercice. Sans baseline, toute détection d'anomalie est impossible. Elle constitue la base de toute stratégie de surveillance dans un SOC.

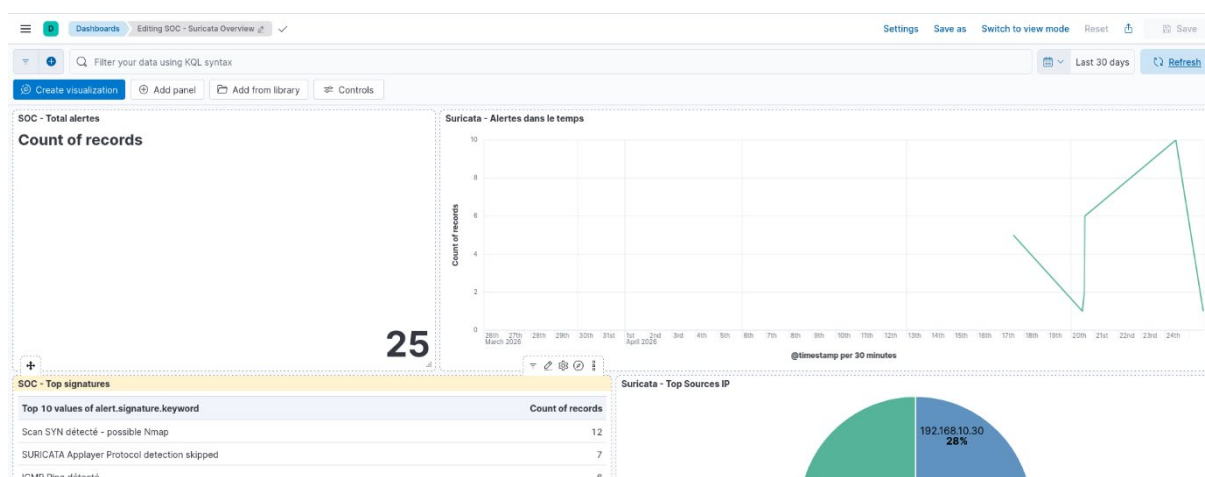


Figure 2 Dashboard Kibana Baseline pré-attaque

3.2 Scan 1 -Découverte réseau : 15:19 UTC+1

Commande exécutée :

```
nmap -sn 192.168.10.0/24
```

```

(root@kali)-[~]
# nmap -sn 192.168.10.0/24
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-25 15:19 +01
Nmap scan report for 192.168.10.20
Host is up (0.0016s latency).
MAC Address: 08:00:27:8A:67:73 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.10.30
Host is up (0.0026s latency).
MAC Address: 08:00:27:5B:84:70 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.10.10
Host is up.
Nmap done: 256 IP addresses (3 hosts up) scanned in 28.14 seconds

```

Figure 3 Scan 1 – Commande nmap -sn

Résultat :

256 adresses IP sondées

3 hôtes détectés comme actifs :

- 192.168.10.10 (Kali – machine source, réponse directe)
- 192.168.10.20 (cible Ubuntu, latence 0.0016s)
- 192.168.10.30 (ELK Stack, latence 0.0026s)

Durée du scan : 28.14 secondes

Analyse : Le ping scan (-sn) n'effectue pas de scan de ports. Son objectif est purement la cartographie des hôtes actifs. Il génère peu d'alertes mais constitue la première étape de reconnaissance d'un attaquant cherchant à identifier les cibles potentielles dans un réseau d'entreprise.

3.3 Scan 2 -Scan SYN furtif (stealth) : 15:20 UTC+1

Commande exécutée :

```
nmap -sS 192.168.10.20
```

```
(root@kali)-[~]
# nmap -sS 192.168.10.20
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-25 15:20 +01
Nmap scan report for 192.168.10.20
Host is up (0.00093s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
MAC Address: 08:00:27:8A:67:73 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 13.37 seconds
```

Figure 4 Scan 2 – Commande nmap -sS

Résultat :

- 999 ports TCP fermés (réponse RST)
- 1 port ouvert : 22/tcp (SSH)
- Latence hôte : 0.00093s
- Durée du scan : 13.37 secondes

Analyse : Le scan SYN (dit "stealth scan") envoie un paquet SYN et attend un SYN-ACK sans jamais compléter le handshake TCP à trois voies. Cette technique vise à passer sous le radar des systèmes de détection moins sophistiqués car aucune connexion complète n'est établie. Les règles custom de local.rules ont été conçues précisément pour détecter ce vecteur.

Impact SOC : Ce scan représente l'élément principal de validation de l'exercice. La règle « Scan SYN détecté – possible Nmap » s'est déclenchée en temps réel, ce qui montre la capacité de détection du système IDS Suricata.

3.4 Scan 3 -Détection de services et versions : 15:26 UTC+1

Commande exécutée :

```
nmap -sV 192.168.10.20
```

```

(root@kali)-[~]
# nmap -sV 192.168.10.20
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-25 15:26 +01
Nmap scan report for 192.168.10.20
Host is up (0.00100s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.14 (Ubuntu Linux; protocol 2.0)
MAC Address: 08:00:27:8A:67:73 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.97 seconds

```

Figure 5 Scan 3 – Commande nmap -sV

Résultat :

- Port 22/tcp ouvert → Service identifié : OpenSSH 8.9p1 Ubuntu 3ubuntu0.14
- OS détecté : Linux
- CPE : cpe:/o:linux:linux_kernel
- Durée du scan : 13.97 secondes

Analyse : La détection de version constitue une escalade dans la phase de reconnaissance. Un attaquant disposant du numéro de version exact du service SSH peut désormais rechercher des vulnérabilités connues liées à cette version (ex : searchsploit openssh 8.9). Cette information est très importante pour la gestion des vulnérabilités, car elle permet de savoir si un système est exposé à des failles connues et doit être mis à jour ou corrigé.

3.5 Scan 4 -Détection OS : 15:27 UTC+1

Commande exécutée :

```
nmap -O 192.168.10.20
```



```

(root@kali)-[~]
# nmap -O 192.168.10.20
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-25 15:27 +01
Nmap scan report for 192.168.10.20
Host is up (0.0017s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
MAC Address: 08:00:27:8A:67:73 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.8
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.16 seconds

```

Figure 6 Scan 4 – Commande nmap -O

Résultat :

- Type de périphérique : general purpose
- OS identifié : Linux 4.X / 5.X
- OS CPE : cpe:/o:linux:linux_kernel:4 et cpe:/o:linux:linux_kernel:5
- OS details : Linux 4.15 – 5.8
- Distance réseau : 1 hop

Analyse : La détection du système d'exploitation (OS) par Nmap se base sur l'analyse du comportement du réseau (comme le TTL, la taille de la fenêtre TCP et certaines options IP). La précision est correcte : la machine cible est bien un système Ubuntu Linux.

Dans un contexte réel de SOC, cette information permet d'identifier les mises à jour nécessaires pour le système d'exploitation et d'organiser les actions de correction par priorité.

3.6 Scan 5 -Scan agressif complet : 15:28 UTC+1

Commande exécutée :

```
nmap -A 192.168.10.20 -oN /home/kali/scan_results.txt
```

```

(root@kali)-[~]
# nmap -A 192.168.10.20 -oN /home/kali/scan_results.txt
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-25 15:28 +01
Nmap scan report for 192.168.10.20
Host is up (0.0012s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.14 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|_  256 78:ac:97:26:89:5a:a0:a3:98:c0:90:9f:45:97:17:8a (ECDSA)
|_  256 bd:c6:d5:88:82:ca:d3:09:01:fe:e2:50:ab:6b:28:ca (ED25519)
MAC Address: 08:00:27:8A:67:73 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.8
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   1.22 ms  192.168.10.20

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.00 seconds

```

Figure 7 Scan 5 – Commande nmap -A

Résultat :

- Port 22/tcp ouvert → OpenSSH 8.9p1 (protocole 2.0)
- SSH Host Keys exposées :

ECDSA : 256 78:ac:97:26:89:5a:a0:a3:98:c0:90:9f:45:97:17:8a

ED25519 : 256 bd:c6:d5:88:82:ca:d3:09:01:fe:e2:50:ab:6b:28:ca

- OS : Linux 4.15 – 5.8
- TRACEROUTE : 1 hop — 1.22ms vers 192.168.10.20
- Résultats sauvegardés dans /home/kali/scan_results.txt
- Durée du scan : 16.00 secondes

Analyse : Le scan agressif -A est la combinaison la plus bruyante proposée par Nmap. Il génère le plus grand volume d'alertes côté IDS. L'exposition des clés SSH de la machine est une information sensible : un attaquant peut utiliser ces empreintes (fingerprints) pour reconnaître la machine dans d'autres réseaux.

La sauvegarde avec l'option (-oN) permet de garder une trace de l'activité, ce qui peut servir comme preuve lors d'une analyse forensique.

4. Analyse du Dashboard Kibana – Visualisation SOC :

4.1 Visualisation 1 : Compteur global d'alertes (KPI)

Valeur observée : 42 alertes (fenêtre 30 jours) / 18 alertes (journée du 25 avril)

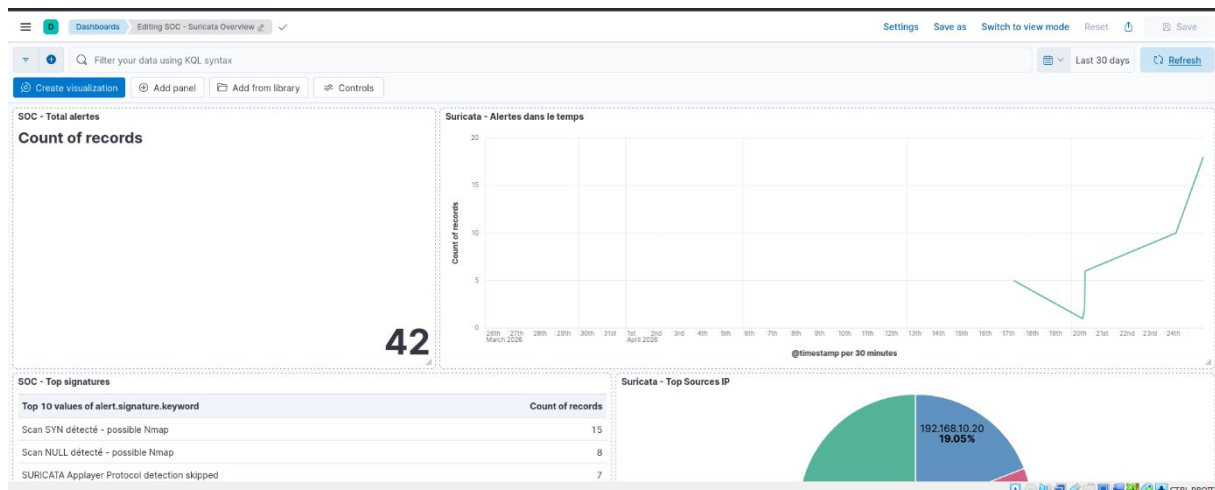


Figure 8 KPI Kibana – Total des alertes (42)

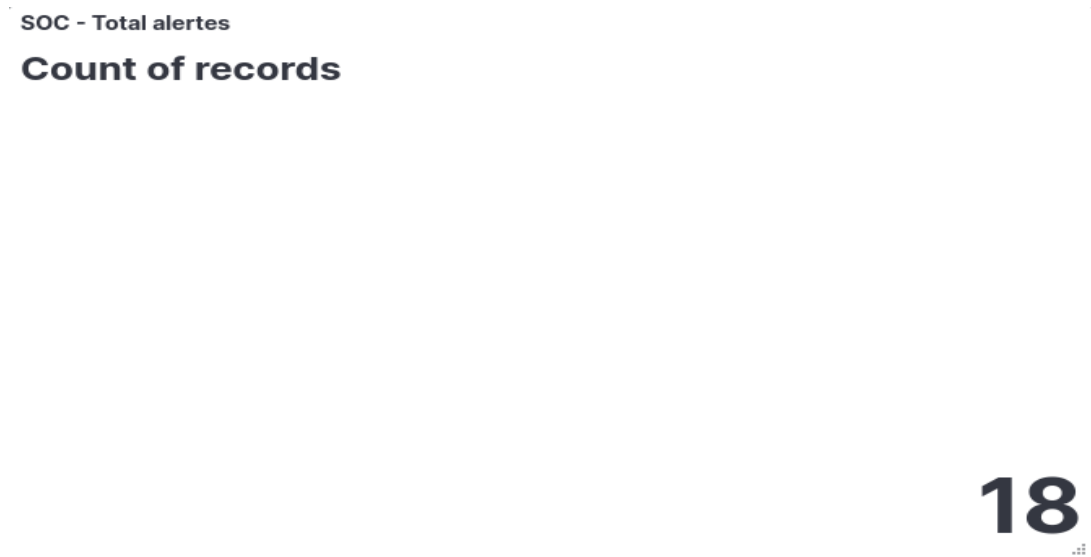


Figure 9 KPI Kibana – 18 alertes concentrées sur la journée du 25 avril 2026.

Le compteur global affiché dans le panneau "SOC – Total alertes" indique 42 enregistrements sur la fenêtre des 30 derniers jours. En restreignant la vue à la journée du 25 avril 2026 (dashboard avec date limitée à "today"), le compteur descend à 18 alertes correspondant précisément à l'activité générée lors de l'exercice.

Interprétation analyste : Le volume de 18 alertes concentrées sur une fenêtre de moins de 10 minutes (15:20–15:28) est incohérent avec un trafic réseau normal sur un réseau de lab en état de repos. Dans un environnement réel, ce type d'activité serait considéré comme suspect, donc on le signale à une personne plus expérimentée (niveau 2) et on ouvre un ticket avec une priorité élevée pour vérifier rapidement.

Le fait que ces alertes apparaissent en même temps que les scans Nmap montre que le système de détection fonctionne correctement du début jusqu'à la fin.

4.2 Visualisation 2 : Évolution temporelle des alertes

Observation : pic isolé à 15:00–16:00 le 25 avril 2026



Figure 10 Graphique temporel – Pic isolé d'alertes entre 15h00 et 16h00.

Le graphique temporel "Suricata – Alertes dans le temps" (granularité : 30 minutes) montre une ligne plate à zéro sur toute la plage de mars et début avril 2026, puis un pic brutal et isolé sur le créneau 15:00–16:00 du 25 avril. Avant et après cette fenêtre de la journée : activité nulle.

4.3 Visualisation 3 : Top signatures déclenchées

Données Kibana observées (journée du 25 avril) :

SOC - Top signatures

Top 10 values of alert.signature.keyword	Count of records
Scan NULL détecté - possible Nmap	8
SURICATA ICMPv4 unknown code	4
Scan SYN détecté - possible Nmap	4
Scan XMAS détecté - possible Nmap	2

Figure 11 Top signatures déclenchées

Interprétation : Le fait de voir en même temps des alertes de type SYN, NULL et XMAS montre que l'attaquant a utilisé plusieurs types de scans différents avec Nmap (notamment avec l'option -A). Les règles ajoutées dans local.rules (Scan SYN, Scan NULL, Scan XMAS) ont bien fonctionné, car elles ont toutes détecté l'activité. L'alerte « ICMPv4 unknown code » vient des messages ICMP envoyés pendant la phase où Nmap essaie d'identifier le système (OS). Donc, on peut dire que le système de détection a bien couvert tous les types de scans utilisés dans cet exercice.

4.4 Visualisation 4 : Top Sources IP (Pie chart)

Données Kibana observées :

Tableau 2 Répartition des alertes par IP source

IP Source	Part
192.168.10.10 (Kali - Attaquant)	88.89%
192.168.10.20 (Target)	11.11%

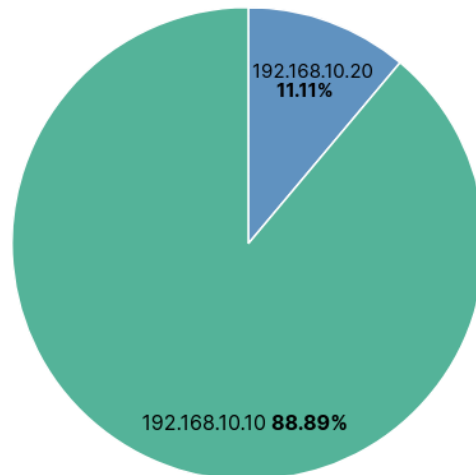


Figure 12 Diagramme circulaire – Top sources IP

L'origine de l'activité est claire : la machine 192.168.10.10 est responsable de la grande majorité des alertes (88,89 %). Les 11,11 % restants viennent de la machine cible (192.168.10.20). Cela correspond aux réponses normales qu'elle envoie (comme TCP RST, SYN-ACK ou ICMP) pendant les scans.

Ce comportement est attendu et normal, car dans un système de détection, on voit à la fois les requêtes envoyées et les réponses reçues.

4.5 Visualisation 5 : Types d'attaques (bar chart)

La visualisation "Suricata – Types d'attaques" reproduit visuellement la même distribution que la table des signatures, avec en tête le Scan NULL (8), suivi de l'ICMPv4 (4) et du Scan SYN (4), puis du Scan XMAS (2).

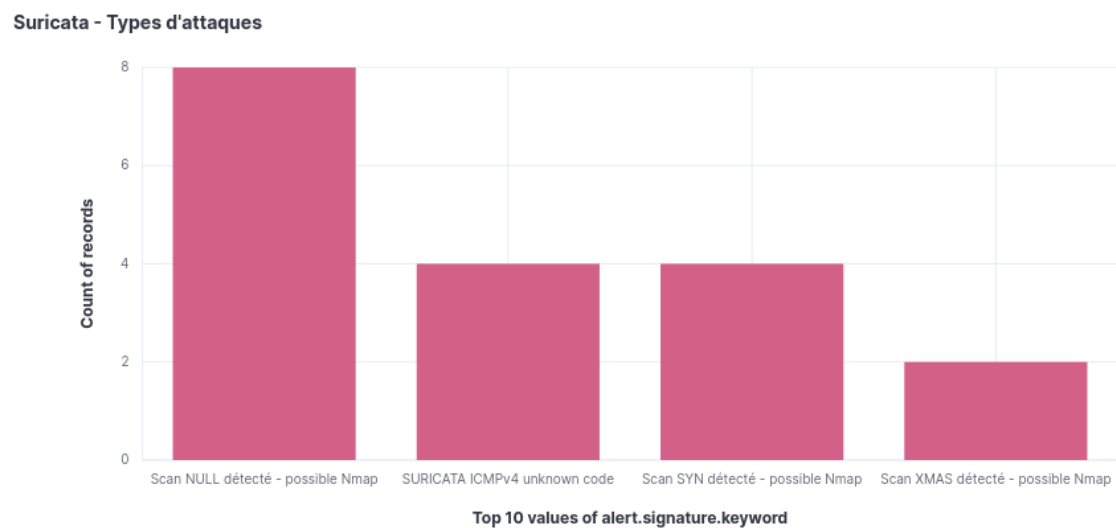


Figure 13 Histogramme – Types d'attaques détectées

4.6 Visualisation 6 : Top ports ciblés

Données Kibana observées :

Tableau 3 Top 5 des ports ciblés

Port	Count approximatif
22 (SSH)	9 (dominant)
1	2
53 (DNS)	1
256	1
1087	1

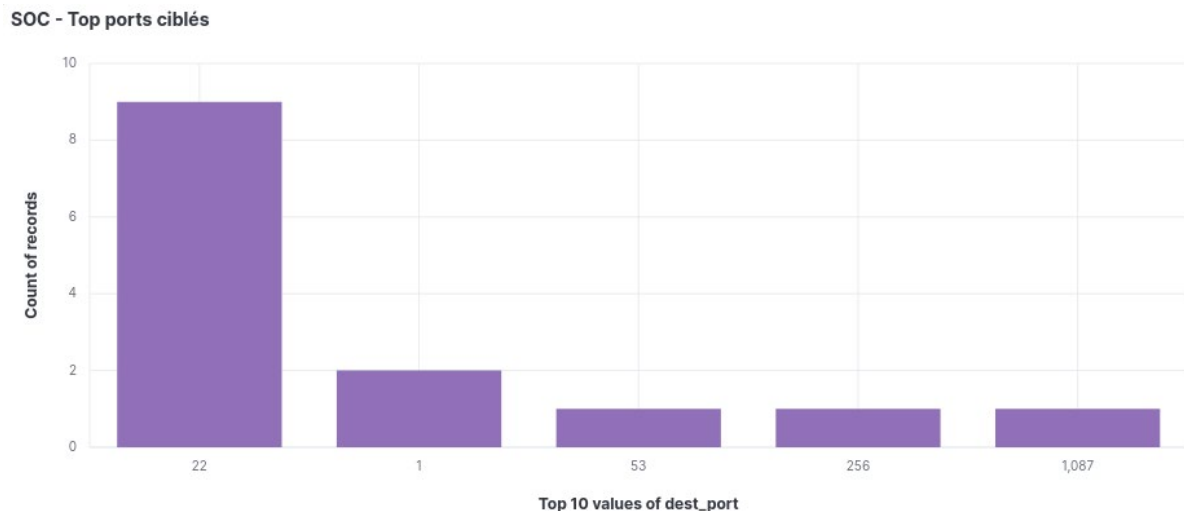


Figure 14 Top ports ciblés

Interprétation : Le port 22 (SSH) est le plus ciblé, ce qui est normal car c'est le seul service ouvert sur la machine 192.168.10.20 (confirmé par Nmap). Les autres ports ont aussi généré des alertes, mais ce sont juste des tentatives de scan sur des ports fermés. La machine répond avec des messages normaux (RST), donc ce n'est pas un vrai accès.

Au final, la surface d'exposition est faible : il n'y a qu'un seul service ouvert (SSH). En plus, la version utilisée (OpenSSH 8.9p1) est récente et ne présente pas de faille critique connue au moment de l'exercice.

5. Analyse des log Suricata - fast.log

Le fichier fast.log consulté via `tail -18 /var/log/suricata/fast.log` confirme les alertes en temps réel avec le détail suivant :

```
04/25/2026-15:20:57 [**] [1:1000002:1] Scan SYN détecté – possible Nmap
{TCP} 192.168.10.10:42787 → 192.168.10.20:53
```

```
04/25/2026-15:26:38 [**] [1:1000002:1] Scan SYN détecté – possible Nmap
{TCP} 192.168.10.10:47055 → 192.168.10.20:1087
```

```
04/25/2026-15:27:31 [**] [1:1000002:1] Scan SYN détecté – possible Nmap
{TCP} 192.168.10.10:39041 → 192.168.10.20:22
```

```
04/25/2026-15:27:33 [**] [1:2200025:2] SURICATA ICMPv4 unknown code
{ICMP} 192.168.10.10:8 → 192.168.10.20:9
```


04/25/2026-15:27:33 [**] [1:1000003:1] Scan NULL détecté – possible Nmap
{TCP} 192.168.10.10:61926 → 192.168.10.20:22

04/25/2026-15:27:33 [**] [1:1000005:1] Scan XMAS détecté – possible Nmap
{TCP} 192.168.10.10:61931 → 192.168.10.20:1

```
(root@kali)-[~]
# tail -18 /var/log/suricata/fast.log
04/25/2026-15:20:57.566546 [**] [1:1000002:1] Scan SYN détecté - possible Nmap [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.10:42787 → 192.168.10.20:53
04/25/2026-15:26:38.760796 [**] [1:1000002:1] Scan SYN détecté - possible Nmap [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.10:47055 → 192.168.10.20:1087
04/25/2026-15:27:31.971595 [**] [1:1000002:1] Scan SYN détecté - possible Nmap [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.10:39041 → 192.168.10.20:22
04/25/2026-15:27:33.114147 [**] [1:2200025:2] SURICATA ICMPv4 unknown code [**] [Classification: Generic Protocol Command Decode] [Priority: 3] {ICMP} 192.168.10.10:8 → 192.168.10.20:9
04/25/2026-15:27:33.115661 [**] [1:2200025:2] SURICATA ICMPv4 unknown code [**] [Classification: Generic Protocol Command Decode] [Priority: 3] {ICMP} 192.168.10.20:0 → 192.168.10.10:9
04/25/2026-15:27:33.216659 [**] [1:1000003:1] Scan NULL détecté - possible Nmap [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.10:61926 → 192.168.10.20:22
04/25/2026-15:27:33.345506 [**] [1:1000005:1] Scan XMAS détecté - possible Nmap [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.10:61931 → 192.168.10.20:1
04/25/2026-15:27:33.371487 [**] [1:1000003:1] Scan NULL détecté - possible Nmap [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.10:61926 → 192.168.10.20:22
04/25/2026-15:27:33.471880 [**] [1:1000003:1] Scan NULL détecté - possible Nmap [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.10:61926 → 192.168.10.20:22
04/25/2026-15:27:33.573399 [**] [1:1000003:1] Scan NULL détecté - possible Nmap [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.10:61926 → 192.168.10.20:22
```

Figure 15 Extrait du fichier fast.log de Suricata

Analyse des logs :

- ✓ La lecture des logs Suricata confirme plusieurs éléments critiques : Cohérence temporelle : Les timestamps des alertes correspondent exactement aux fenêtres d'exécution des scans Nmap (15:20 pour le scan SYN, 15:27 pour le scan agressif - A).
- ✓ Identification des règles custom : Les SIDs 1:1000002, 1:1000003, 1:1000005 correspondent aux règles définies dans local.rules (SID > 1000000 = règle locale).

Traçabilité complète : Chaque entrée contient l'IP source, l'IP destination, le port source éphémère et le port destination ciblé, données suffisantes pour une corrélation forensique et une reconstruction de la session.

Multi-vecteurs simultanés : À 15:27:33, trois types de scans différents (ICMPv4, NULL, XMAS) sont loggués à la milliseconde près, confirmant le comportement du scan -A qui parallélise ses techniques de découverte.

La capture de l'interface Kibana Discover (index suricata-*, filtre event_type.keyword: "alert") montre 613 champs disponibles dans le schéma, avec 18 documents correspondant aux alertes de la journée.



- event_type : alert
- @timestamp : 2026-04-25T15:28:38.976Z
- alert.signature : Scan NULL détecté – possible Nmap
- alert.severity : 3
- alert.action : allowed
- alert.category : (null)
- src_ip : 192.168.10.10
- dest_ip : 192.168.10.20

- dest_port : 22
- direction : to_server
- ecs.version : 0.0.0

Note analyste : Le champ alert.action: allowed indique que Suricata est configuré en mode IDS (détection seule) et non IPS (prévention/blocage). Dans un contexte de production, une règle de type drop plutôt que alert aurait automatiquement bloqué le trafic suspect. La migration vers un mode IPS est une recommandation de remédiation documentée dans ce rapport.

7. Résumés des indicateurs de compromission (IoC)

Tableau 4 Indicateurs de compromission (IoC)

Type	Valeur	Contexte
IP Source	192.168.10.10	Machine Kali – origine de 88.89% des alertes
IP Cible	192.168.10.20	Ubuntu Server – cible unique
Port exposé	22/tcp	SSH – seul service ouvert
Service identifié	OpenSSH 8.9p1 Ubuntu	Version et OS fingerprinting réussis
Clé SSH ECDSA	78:ac:97:26:89:5a:...	Exposée par scan -A
Clé SSH ED25519	bd:c6:d5:88:82:ca:...	Exposée par scan -A
OS détecté	Linux 4.15 – 5.8	Via TCP/IP fingerprinting
Outil d'attaque	Nmap 7.94SVN	Version identifiable via User-Agent NSE
Distance réseau	1 hop (1.22ms RTT)	Attaquant sur le même segment réseau

8. Recommandations de remédiation :

Immédiat (0-24h)

Bloquer l'IP 192.168.10.10 au niveau firewall en attendant investigation complète de la machine source (dans un contexte réel).

Restreindre SSH (port 22) par liste blanche IP n'autoriser que les IPs administratives connues.

Passer Suricata en mode IPS (drop au lieu de alert) pour les règles de scan validées.

Court terme (1-7 jours)

Implémenter Fail2Ban sur la machine cible pour limiter le brute-force SSH post-reconnaissance. Fail2Ban est un outil de sécurité qui surveille les tentatives de connexion. Si une même adresse IP fait plusieurs tentatives échouées, il la bloque automatiquement pendant un certain temps via le firewall.

Désactiver l'authentification par mot de passe SSH activer l'authentification par clé uniquement (PasswordAuthentication).

Enrichir les règles Suricata en ajoutant des seuils (thresholds) pour limiter les fausses alertes et rendre les alertes plus pertinentes.

Configurer des alertes Kibana (Alerting) pour notifier automatiquement le SOC en cas de pic d'alertes dépassant un seuil défini.

Moyen terme (1-4 semaines)

Segmenter le réseau avec des VLANs et un pare-feu inter-zone pour limiter la surface de scan.

Implémenter un honeypot sur des ports non utilisés pour détecter les scans latéraux.

Conclusion :

L'exercice de détection mené le 25 avril 2026 a permis de valider l'efficacité de la chaîne de détection Suricata → Logstash → Elasticsearch → Kibana sur l'ensemble des vecteurs de scan testés.

Les règles personnalisées local.rules ont correctement déclenché sur les scans SYN, NULL et XMAS. Le SIEM Kibana a correctement récupéré, indexé et affiché les alertes en temps quasi-réel. La visualisation du dashboard SOC permet une lecture immédiate de la situation : volume d'alertes, timeline, attribution de source, nature des attaques et ports ciblés.

La surface d'exposition de la cible est minimale : un seul port ouvert (SSH/22), service à jour. Aucune tentative d'exploitation post-reconnaissance n'a été observée.

En contexte SOC réel, cet incident aurait justifié une escalade P2 (High), c'est-à-dire un incident de priorité élevée qui nécessite une analyse rapide et une intervention dans un court délai. un blocage immédiat de l'IP source, et l'ouverture d'une investigation forensique sur la machine 192.168.10.10 pour déterminer si elle est compromise ou si l'activité est intentionnelle (pentest non autorisé, insider threat).